Build & Break a Mini Secure Channel with Blockchain-based Decentralized Authentication

Παρουσίαση εργασίας στο μάθημα της κρυπτογραφίας

Καθηγήτρια: Σοφία Πετρίδου

ΣΤΥΛΙΑΝΟΣ ΒΑΣΙΛΕΙΟΥ - MAI260004 - MsC ΕΦΑΡΜΟΣΜΕΝΗΣ ΠΛΗΡΟΦΟΡΙΚΗΣ

ΕΛΛΗΝΙΚΗ ΔΗΜΟΚΡΑΤΙΑ
ΠΑΝΕΠΙΣΤΗΜΙΟ ΜΑΚΕΔΟΝΙΑΣ

Κίνητρο της Εργασίας

Κύριοι προβληματισμοί

- Τα Secure channels αντιμετωπίζονται συχνά ως “μαύρα κουτιά”. Η αυθεντικοποίηση, η συμφωνία των κλειδιών και η προστασία των μηνυμάτων παραμένουν «αόρατες», με αποτέλεσμα να μην είναι σαφές ποια ακριβώς ιδιότητα ασφάλειας παρέχεται και πότε.

- Οι κεντρικοποιημένες υποδομές δημοσίων κλειδιών και οι αρχές πιστοποίησης έχουν αναδειχθεί ως μοναδικά σημεία αστοχίας (single points of failure) για ολόκληρο το οικοσύστημα ασφάλειας.

Το κίνητρο της εργασίας προκύπτει από τη σύνδεση των παραπάνω: **Χτίζουμε το** secure channel σε διαφορετικές φάσεις και στη συνέχεια προσθέτουμε **αποκεντρωμένη αυθεντικοποίηση,** με σκοπό να αντιμετωπίσουμε τα δύο αυτά προβλήματα.

Γιατί χρειάζεται το «χτίσιμο» σε φάσεις;

- **Κύριος στόχος**: να απομονωθούν τα δομικά στοιχεία ενός secure channel και μέσω demo να φανούν οι αδυναμίες του και το πώς αυτές σταδιακά καλύπτονται.
  - Πχ. Μη αυθεντικοποιημένος Diffie-Hellman -> ευάλλωτος σε επίθεση man-in-the-middle -> επομένως προσθέτουμε αυθεντικοποιημένο handshake.
- **Αποδόμηση** του Secure channel:

Ανταλλαγή Κλειδιών

X25519 + HKDF

Αυθεντικοποίηση

Ed25519 + Blockchain

Ασφαλής Επικοινωνία

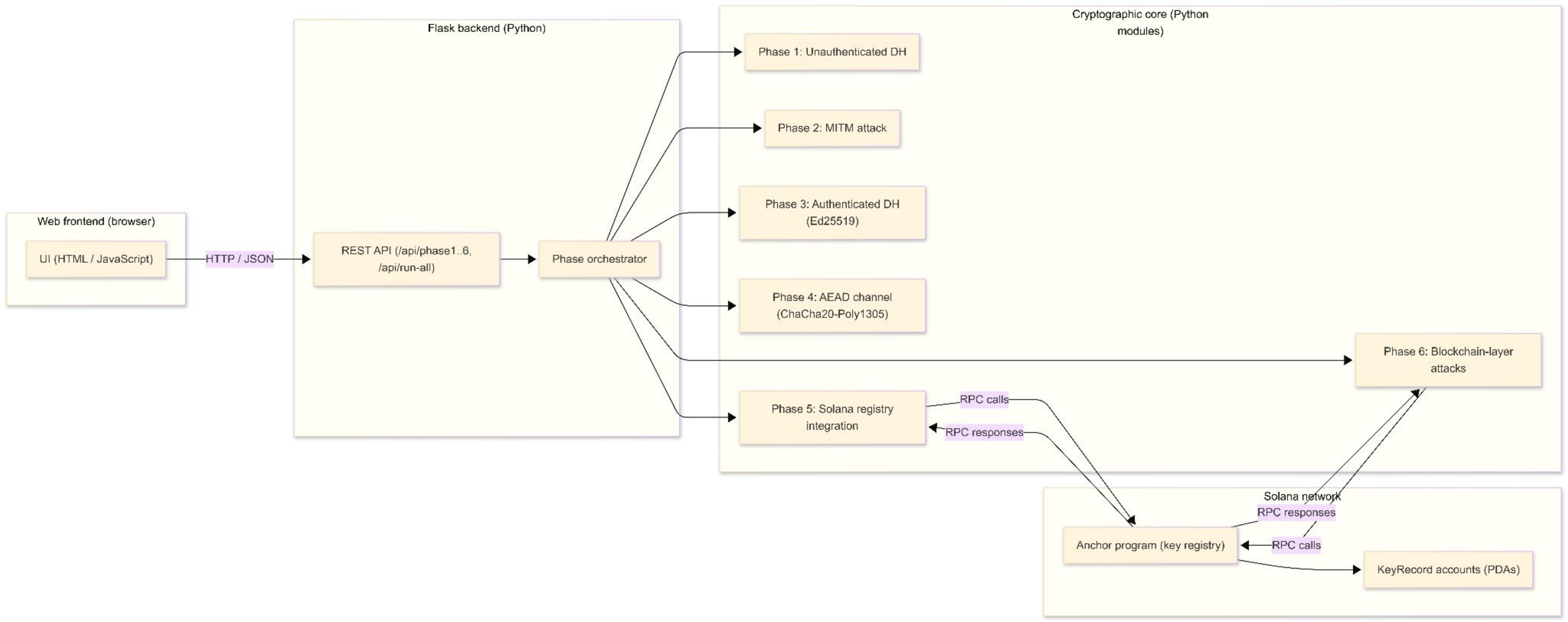
ChaCha20-Poly1305 (AEAD)

Αρχιτεκτονική του συστήματος

Σύνοψη των φάσεων και των τεχνολογιών της υλοποίησης

- 6 φάσεις: X25519 DH → MITM demo → AuthDH (Ed25519) → AEAD (ChaCha20-Poly1305) → μητρώο κλειδιών Solana → σενάρια επιθέσεων στο blockchain.
- Πλήρης web εφαρμογή: HTML/JavaScript UI + Flask REST API, με ορατά κλειδιά και logs
- Solana/Anchor smart contract (KeyRecord PDA) + Python client για on-chain καταχώριση και επαλήθευση των κλειδιών.

Αρχιτεκτονική του συστήματος



Μοντέλο Απειλών

Ορισμός των δυνατοτήτων των αντιπάλων

- Ενεργός επιτιθέμενος δικτύου: υποκλοπή/τροποποίηση/αντικατάσταση των handshake μηνυμάτων (man-in-the-middle).
- Επιτιθέμενος με δυνατότητα τροποποίησης των μηνυμάτων: αλλοίωση των ciphertexts (tampering).
- Επιτιθέμενος στο blockchain: απόπειρες μη εξουσιοδοτημένης καταχώρισης κλειδιών (mis-registration) και αντικατάστασης κλειδιών (key substitution) στο μητρώο.

Υλοποίηση του συστήματος σε 6 φάσεις

Κάθε φάση εισάγει μία βελτίωση ασφαλείας

Φάση 1
Diffie Hellman
(X25519 + HKDF)

Φάση 2
MITM
(Επίθεση του Mallory)

Φάση 3
Auth
Diffie Hellman
(Ed25519)

Φάση 4
AEAD
(ChaCha20-Poly1305)

Φάση 5
Μητρώο
Solana
(KeyRecord PDA)

Φάση 6
Blockchain
Επιθέσεις

- Φάσεις 1-2: Παρουσιάζουμε το πρόβλημα (Μη αυθεντικοποιημένος Diffie-Hellman).
- Φάσεις 3-4: Βελτιώνουμε την ασφάλεια (Αυθεντικοποίηση & AEAD).
- Φάσεις 5-6: Προσθέτουμε το on-chain μητρώο και επιβεβαιώνουμε την αντοχή του σε επιθέσεις.

Φάση 1

Μη αυθεντικοποιημένος Diffie–Hellman (X25519 + HKDF)

- Δημιουργία του ζεύγους κλειδιών X25519 για την Alice και τον Bob και ανταλλαγή των δημοσίων κλειδιών τους.
- Υπολογισμός του κοινού μυστικού από το (private key, peer public key) και στη συνέχεια παραγωγή του 32-byte κλειδιού με το HKDF-SHA256.
- Η Alice και ο Bob καταλήγουν στο ίδιο συμμετρικό κλειδί χωρίς να υπάρχει κάποιος έλεγχος ταυτότητας → οποιοσδήποτε μπορεί να “σταθεί” ανάμεσα τους χωρίς να γίνει αντιληπτός.

Συμπέρασμα: το πρωτόκολλο δεν αποτρέπει την αντικατάσταση των δημοσίων κλειδιών σε ένα μη ασφαλές δίκτυο.

Φάση 2

Επίθεση Man-in-the-middle

- Ο Mallory παρεμβάλλεται στο handshake και αντικαθιστά τα δημόσια κλειδιά που ανταλλάσσουν η Alice και ο Bob.
- Αυτό έχει ως αποτέλεσμα να δημιουργούνται δύο ανεξάρτητα κοινά μυστικά: ένα μεταξύ Alice-Mallory και ένα μεταξύ Bob-Mallory, με διαφορετικά συμμετρικά κλειδιά.
- Επομένως η Alice και ο Bob πραγματοποιούν συμφωνία κλειδιού με κάποιον (Mallory), αλλά η Alice και ο Bob δεν μοιράζονται ποτέ κάποιο κοινό κλειδί μεταξύ τους.

Συμπέρασμα: ο μη αυθεντικοποιημένος Diffe-Hellman δεν αρκεί σε ένα εχθρικό δίκτυο.

Φάση 3

Αυθεντικοποιημένος Diffie-Hellman (Ed25519)

- Κάθε συμμετέχον διαθέτει ένα κλειδί ταυτότητας Ed25519 και υπογράφει τα μηνύματα handshake.
- Ο παραλήπτης του μηνύματος επαληθεύει την υπογραφή πριν αποδεχθεί το δημόσιο κλειδί DH και πριν ολοκληρώσει τη συμφωνία κλειδιού.
- Αυτή η διαδικασία έχει ως αποτέλεσμα ο Mallory να μη μπορεί να αντικαταστήσει τα κλειδιά χωρίς να αποτύχει η επαλήθευση υπογραφής, καθώς το handshake θα απορρίπτεται.

Συμπέρασμα: η αυθεντικοποίηση αποτρέπει την επίθεση MITM.

Φάση 4

AEAD Secure Channel (ChaCha20-Poly1305)

- Εφόσον υπάρχει αυθεντικοποιημένος Diffie-Hellman, τώρα δημιουργείται secure channel και γίνεται κρυπτογράφιση/αποκρυπτογράφιση των μηνυμάτων με ChaCha20-Poly1305 (AEAD).
- Το ciphertext συνοδεύεται από tag αυθεντικοποίησης και nonce. Ο παραλήπτης το επαλυθεύει και το αποκρυπτογραφεί.
- Σε περίπτωση αλλοίωσης του μήνυματος (tampering - αλλαγή bytes), η αποκρυπτογράφηση αποτυγχάνει και το μήνυμα απορρίπτεται.

Συμπέρασμα: οποιαδήποτε μη εξουσιοδοτημένη τροποποίηση εντοπίζεται και απορρίπτεται.

Φάση 5

On-chain Μητρώο Κλειδιών (Solana / Anchor PDA)

- Για κάθε πορτοφόλι (Solana address) δημιουργείται μια on-chain εγγραφή (KeyRecord PDA).
- Μέσα σε αυτή την εγγραφή αποθηκεύεται το δημόσιο κλειδί Ed25519 που αντιστοιχεί σε αυτή την ταυτότητα (δηλαδή γίνεται αντιστοίχιση “address → identity public key”).
- Για να επαληθευτεί η εγγραφή, διαβάζεται από το blockchain ποιο κλειδί είναι καταχωρισμένο για το κάθε πορτοφόλι και ελέγχεται αν ταιριάζει με το κλειδί που παρουσιάζεται εκτός της αλυσίδας.

Συμπέρασμα: Η αντιστοίχιση ταυτότητας-κλειδιού μεταφέρεται σε έναν δημόσια επαληθεύσιμο on-chain μηχανισμό, επιτρέποντας την ανεξάρτητη επιβεβαίωση των ταυτοτήτων.

Φάση 6

Αντιμετώπιση των επιθέσεων στο blockchain

- Πραγματοποιούνται επιθέσεις όπου ο Mallory επιχειρεί να καταχωρίσει το κλειδί του σε κάποιο ξένο wallet (mis-registration) και να παρουσιάσει διαφορετικό δημόσιο κλειδί ως το “σωστό” για μια δεδομένη ταυτότητα (key substitution).

- Οι απόπειρες mis-registration αποτυγχάνουν, καθώς η μέθοδος registerKey απαιτεί η συναλλαγή να υπογράφεται από τον ιδιοκτήτη του αντίστοιχου πορτοφολιού, άρα δεν είναι δυνατόν κάποιος τρίτος να δημιουργήσει/τροποποιήσει εγγραφή για κάποια ξένη ταυτότητα.

- Οι απόπειρες substitution αποτυγχάνουν, καθώς η μέθοδος verifyKey εκτελεί μία on-chain σύγκριση μεταξύ του δημοσίου κλειδιού και του κλειδιού του mallory, επιστρέφοντας αποτυχία εφόσον δεν υπάρχει αντιστοίχιση.

Συμπέρασμα: το μητρώο εξασφαλίζει ότι μόνο ο πραγματικός κάτοχος μιας διεύθυνσης μπορεί να καταχωρίσει το αντίστοιχο δημόσιο κλειδί του και ότι κάθε έλεγχος μπορεί να επιβεβαιώσει αν το κλειδί ταιριάζει με την on-chain εγγραφή, αποτρέποντας πρακτικά σενάρια επιθέσεων στο blockchain.

Σύνοψη & Συμπεράσματα

Σύνοψη των συμπερασμάτων των φάσεων

- Φάσεις 1-2: ο Diffie-Hellman χωρίς αυθεντικοποίηση αποτυγχάνει σε ένα εχθρικό δίκτυο (MITM).
- Φάσεις 3-4: ο αυθεντικοποιημένος Diffie-Hellman μαζί με το AEAD μετατρέπουν τη συμφωνία κλειδιού σε ένα ασφαλές κανάλι ανταλλαγής μηνυμάτων.
- Φάσεις 5-6: το on-chain μητρώο παρέχει δημόσια επαληθεύσιμη αντιστοίχιση ταυτότητας-κλειδιού και αποτρέπει τις επιθέσεις mis-registration/key substitution μέσω on-chain περιορισμών.